

Do you think you know what it takes to create a secure password in 2024? How can you ensure your company's systems users and employees are creating passwords that will protect confidential data, keep communications private, and prevent cyberattacks from damaging the company's reputation and bottom line?

The National Institute of Standards and Technology (NIST) regularly updates its Digital Identity Guidelines, including password creation and secrets management. Identity best practices. Read on to learn more about NIST password guidelines, and why NIST standards are important for your company to follow.

Why Is Password Security So Important?

Password cracking attacks remain a viable vector for threat actors, and passwords remain some of the most vulnerable targets for hackers. By obtaining valid passwords and user credentials, attackers can infiltrate systems and even escalate their privileges to an administrator or superuser level. Attackers can access sensitive personal, financial, and professional information, leading to identity theft, financial fraud, and reputational damage.

By following the NIST password guidelines, businesses can safeguard their information security assets, adhere to compliance requirements, and apply best practices recognized by the US and worldwide.

NIST Password Guideline Standards

Originally published in 2017 in compliance with the Federal Information Security Modernization Act of 2014 for federal agencies and most recently updated in 2020, the NIST Password Guideline Standards are laid out in NIST Special Publication (SP) 800-63B and are part of NIST's Digital Identity Guidelines document suite. NIST has not only focused on the quality of user passwords being created, but also the behaviors of the people creating those passwords so it can offer informed recommendations on how to create, authenticate, implement, store, and update passwords over time. Here's a synopsis:

1. Enable 'Show Password'

It's unlikely the person behind you is going to record your password data, so there's little reason to hide your password as you type. You're more likely to make mistakes in typing if you can't see the characters, and mistakenly think you've forgotten your password. This error leads to potential data exposure every time you need to reset your password. Many of the applications today provide a 'password visibility' toggle button or an 'eye symbol' to display the password while typing allowing users to verify their input without compromising security.

2. Use a Password Manager for Increased Password Strength

NIST suggests companies use a password manager to help their employees and stakeholders encrypt and generate strong passwords. Even if you're securing your own servers, you will want to help reduce human error by giving your users access to a password manager, which will automatically generate long, strong passwords and passphrases for them. Password managers that plug into the browser, can seamlessly determine the access to your frequent passwords for cloud services, web applications, or even local applications. Modern browsers that integrate with password managers request to re-authenticate using biometrics to reveal the password, which will be an additional layer on top of the MFA for the application.

Research shows that user behaviors have a major impact on password security, and that many people will opt to reuse passwords rather than create an entirely new password based on security guidelines.

Using the same password across multiple systems can create more than one vulnerability, and are prone to 'credential stuffing' attacks, whereby the attackers use the same credentials to gain unauthorized access to your other accounts. Providing employees with a password manager and appropriate training encourages them to use new, different passwords for each system, and helps users remember their credentials.

3. Store Secrets Securely through Salting and Hashing

NIST requires organizations to remove the user-generated password from their server as soon as it is created, either using a zero-knowledge password protocol or zeroization. They recommend "hashing" and "salting" passwords. NIST defines a hash as "a function that maps a bit string of arbitrary length to a fixed-length bit string." In other words, by "hashing" a plain-text password, you're converting that password into a fixed-length (e.g. 32 character) string that's gobbledygook, also known as a password hash. Using hashes to store password data will ensure you never expose a database of plain-text passwords to a hacker; instead, they'd get a list of hashes that would take much longer to crack and give you more time to recuperate. Salting adds extra data to passwords before they are hashed to make stored passwords even harder to exploit. It is also a best practice to generate a unique salt for each password stored in the database.

Be sure to use modern, secure salting and hashing methods (Example: Argon2id, bcrypt, and PBKDF2), as some older algorithms (Example: MD5 or SHA-1) may no longer be secure.

4. Lock After Multiple Attempts

NIST suggests locking a user out of password-protected programs if they use an incorrect password multiple times. Section 5.22 of Special Publication NIST 800-63b, which provides guidelines for "rate-limiting" on authentication attempts, requires that you allow no more than 100 password attempts to input a password. However, for security, most organizations will limit far before that threshold and also use strategies like making a user wait a period of time before attempting to sign on again. In addition to capping login attempts and setting up timeouts, businesses can also employ CAPTCHAs and IP address "Permit" lists (AKA "whitelists") to combat bot-based attacks.

5. Employ Two-Factor Authentication or Multi-Factor Authentication

Two-factor (2FA) or multi-factor authentication (MFA) involves requiring users to authenticate using two or more factors or methods. One factor of authentication in this model can be a secret or password — something you know. Adding another factor, like a code received through SMS on your phone or using a TOTP authenticator app — something you have — reduces the risk that a password breach alone would compromise the business or a user's account. Most MFA authenticators that run on smartphones, require the phone to be unlocked with any of the known methods (biometrics or pin) to reveal the MFA pin as a part of the authentication workflow. Physical security keys, like the Yubikey products, can also serve as something you have. Although biometrics — something you are — can serve as another factor, NIST's updates in 2020 indicate that biometrics should only be used in a limited capacity for authentication.

NIST is not alone in recommending that MFA be incorporated into password policies and password security processes — increasingly, third parties, auditors, and customers are looking for MFA in the products and solutions they choose to combat the prevalence of identity theft, cyber threats, and fraud.

Frequency of Password Changes

Contrary to popular belief and prior standards, NIST does not suggest frequent password changes (example: every 60 or 90 days); individuals who are asked to change passwords frequently are much more likely to reuse an old password and merely append a number, letter, or special character to the end of it. Professional hackers know this trick and are savvy enough to predict minor changes. Plus, if a previous password has already been compromised, any derivations of that password, even if additional characters are added or modified, are more easily breached in the future.

NIST recommends that businesses enforce password expiration and password resets only when a known compromise has occurred, or every 365 days. The shift to longer password life is intended to encourage users to generate longer passwords that are harder to crack.

NIST's New Guidelines for Passwords

NIST SP-800-63 was originally released in 2017, but has gone through various iterations and is constantly being revised. As of 2024, NIST has requested comments on their newest revision of 800-63 (Digital Identity Guidelines). As recently as 2020, NIST revised their password guidelines to emphasize password length over complexity requirements, salting and hashing stored passwords, MFA, and making it easier for users to adhere to password security policies. Additionally, organizations should not require their employees to reset their passwords more than once per year, and they should monitor new passwords on a daily basis, testing them against lists of common and compromised passwords. Finally, NIST has identified several threats to authentication security, including password security, that businesses and industry professionals should keep in mind. By aligning with these guidelines, organizations can enhance their security posture while maintaining user convenience and reducing the risk of weak passwords.

1. Reduce the Importance of Password Complexity

New NIST password guidelines say you should focus on length, as opposed to complexity when designing a password. Paradoxically, using complex passwords (adding special characters, uppercase letters, lowercase letters, and numbers) may make it easier for brute force attacks to compromise your passwords, and this mostly has to do with user behavior. Although NIST requires only a minimum of eight characters for passwords, generally the longer a password is, the more difficult it is to crack. I personally set passwords to a minimum length of sixteen characters (in my password manager!), though if you're looking for a good middle ground, twelve is a good choice for minimum password length.

2. Monitor New Passwords Automatically

Some passwords are compromised before they are even created; ensure new passwords are not just strong, long, and complex, but they are not on lists of commonly used, easily compromised passwords — sequential strings like “123456” and common words like “password” aren't the only commonly compromised passwords.

3. Threats to Authentication

Passwords serve as the front line of authentication and defense for users and organizations, and breached passwords remain one of the most common cybersecurity threats. By understanding the following threats to authentication identified by NIST, organizations can better define and respond to the security risks that apply to them.

Blog image

4. Eliminate Password Hints

The NIST special publication 800-63B publication prohibits the use of password hints that may help users remember their passwords, as this can give savvy hackers an important clue about that account's password.

NIST Password Recommendations

NIST has a few recommendations that aren't strict requirements, but definitely count as best practices because they facilitate the user experience and reduce the chance that human error will put you in a position to be easy prey for a cyberattack: 1) set the maximum password length at 64 characters, 2) don't require users to select special characters in their passwords, 3) allow copy-and-paste functions in your password fields; this allows password managers to work effectively, 4) allow, ASCII, and Unicode characters in your passwords, and 5) utilize a secure password manager.

NIST Guidelines for Compromised Passwords

As discussed above, NIST suggests you change passwords as soon as you know they are compromised; moreover, your organization should be screening new passwords, automatically if possible. New passwords should be compared to lists of breached, frequently used, and weak passwords to prevent people from using these credentials for their user accounts. In this case, your IT team can use the same tools hackers use to prevent cybersecurity data breaches. Hackers regularly use dictionary words, password lists that sift through commonly used passwords, context-specific words (like the company or service name), previously breached password lists, and hash tables to find patterns across your company's user data. You can use these same techniques to help you filter out compromised (or compromisable) passwords before hackers get the chance.

NIST Password Takeaways

NIST password guidelines are updated regularly, they change with our ever-evolving cyber landscape and are the gold standard for securing your company's sensitive information and creating a strong information security program. To ensure you are compliant, your staff and stakeholders understand effective password creation, you have systems in place to detect compromised passwords, and your servers are adequately guarded against attack, you might want to consider automating the process. Optro's compliance management software will help you navigate the changing NIST requirements to enable your organization to stay in compliance.